Hardening Grafana Alloy Security — macOS, Linux, Windows & Kubernetes

Version: 1.0

Audience: Platform Engineers, SRE Teams, Security Engineers

Scope: Comprehensive security hardening for Grafana Alloy across all platforms

---

Security Hardening Philosophy

This guide follows a **Defence in Depth** approach across seven layers:

Layer	Focus Area
Layer 1	Operating System Hardening
Layer 2	Process Isolation
Layer 3	Network Security
Layer 4	Credential & Secret Management
Layer 5	Configuration Security
Layer 6	Runtime Monitoring

Layer	Focus Area
Layer 7	Audit & Compliance

Table of Contents

1. Universal Security Principles
2. macOS Hardening
3. Linux Hardening
4. Windows Hardening
5. Kubernetes Hardening
6. Configuration Security
7. Network Security
8. Credential & Secret Management
9. TLS Hardening
10. Audit & Monitoring
11. Security Checklist
12. FAQs

---

1. Universal Security Principles

These principles apply to **all platforms**.

Core Security Rules

- Run Alloy as a dedicated non-root service account
- Apply least-privilege permissions to all files and directories

- Never store credentials in configuration files in plaintext
- Enable TLS for all inbound and outbound connections
- Restrict network access to only required endpoints
- Enable audit logging for all Alloy operations
- Pin Alloy to a specific version — never use "latest"
- Regularly rotate all credentials and tokens
- Scan Alloy binary and configuration for vulnerabilities
- Monitor Alloy process for anomalous behaviour

Alloy Security Surface Areas

Attack Surface	Risk	Mitigation
HTTP Listener	Unauthorised access	Auth + TLS
OTLP Receiver	Data injection	Network policy
Remote Write Endpoint	Credential exposure	Secrets manager
Config File	Secret leakage	File permissions
River/Alloy Config	Code injection	Input validation
Prometheus Metrics	Info disclosure	Auth on /metrics
Alloy UI	Unauthorised access	Disable or auth
Component Plugins	Supply chain attack	Verify checksums

Universal Alloy Configuration Security Baseline

```
// config.alloy — Universal Security Baseline
// Apply these settings on ALL platforms

// Disable the Alloy UI in production
// Passed as CLI flag — not in config file
// --server.http.listen-addr=127.0.0.1:12345
// Restricts UI to localhost only

// Logging — structured JSON for SIEM ingestion
logging {
  level  = "warn"     // Reduce log verbosity in production
  format = "json"     // Machine-parseable for SIEM
}

// Tracing — disable if not required
tracing {
  sampling_fraction = 0.0   // Disable internal tracing
}
```

---

2. macOS Hardening

2.1 — Dedicated Service Account

```
# Create a dedicated system user for Alloy
# macOS uses dscl for user management

# Create group
```

```
sudo dscl . -create /Groups/alloy
sudo dscl . -create /Groups/alloy PrimaryGroupID 500

# Create user
sudo dscl . -create /Users/alloy
sudo dscl . -create /Users/alloy UserShell /usr/bin/false
sudo dscl . -create /Users/alloy RealName "Grafana Alloy"
sudo dscl . -create /Users/alloy UniqueID 500
sudo dscl . -create /Users/alloy PrimaryGroupID 500
sudo dscl . -create /Users/alloy NFSHomeDirectory /var/lib/alloy

# Prevent login
sudo dscl . -create /Users/alloy AuthenticationAuthority
";DisabledUser;"

# Create home directory
sudo mkdir -p /var/lib/alloy
sudo chown alloy:alloy /var/lib/alloy
sudo chmod 750 /var/lib/alloy

# Verify
id alloy
```

2.2 — File System Permissions

```
# Create required directories with strict permissions
sudo mkdir -p /etc/alloy
sudo mkdir -p /var/lib/alloy
sudo mkdir -p /var/log/alloy
sudo mkdir -p /etc/alloy/secrets
```

```
# Set ownership
sudo chown -R alloy:alloy /etc/alloy
sudo chown -R alloy:alloy /var/lib/alloy
sudo chown -R alloy:alloy /var/log/alloy

# Set permissions
# Config directory — owner read/write, no group/world access
sudo chmod 750 /etc/alloy
sudo chmod 640 /etc/alloy/config.alloy

# Secrets directory — owner only
sudo chmod 700 /etc/alloy/secrets
sudo chmod 600 /etc/alloy/secrets/*

# Data directory — owner only
sudo chmod 750 /var/lib/alloy

# Log directory
sudo chmod 750 /var/log/alloy

# Alloy binary — read/execute only
sudo chmod 755 /usr/local/bin/alloy

# Verify permissions
ls -la /etc/alloy/
ls -la /etc/alloy/secrets/
```

2.3 — macOS Launchd Service Hardening

```
<!-- /Library/LaunchDaemons/com.grafana.alloy.plist -->
<?xml version="1.0" encoding="UTF-8"?>
```

```
<!DOCTYPE plist PUBLIC "-//Apple//DTD PLIST 1.0//EN"
  "http://www.apple.com/DTDs/PropertyList-1.0.dtd">
<plist version="1.0">
<dict>
  <key>Label</key>
  <string>com.grafana.alloy</string>

  <key>ProgramArguments</key>
  <array>
    <string>/usr/local/bin/alloy</string>
    <string>run</string>
    <string>/etc/alloy/config.alloy</string>
    <!-- Bind to localhost only — restrict UI access -->
    <string>--server.http.listen-addr=127.0.0.1:12345</string>
    <!-- Disable remote configuration -->
    <string>--disable-reporting=true</string>
    <!-- Stability level -->
    <string>--stability.level=generally-available</string>
  </array>

  <!-- Run as dedicated service account -->
  <key>UserName</key>
  <string>alloy</string>
  <key>GroupName</key>
  <string>alloy</string>

  <!-- Start on boot -->
  <key>RunAtLoad</key>
  <true/>

  <!-- Restart on failure -->
  <key>KeepAlive</key>
```

```
  <dict>
    <key>SuccessfulExit</key>
    <false/>
  </dict>

  <!-- Working directory -->
  <key>WorkingDirectory</key>
  <string>/var/lib/alloy</string>

  <!-- Standard output to log file -->
  <key>StandardOutPath</key>
  <string>/var/log/alloy/alloy.log</string>
  <key>StandardErrorPath</key>
  <string>/var/log/alloy/alloy-error.log</string>

  <!-- Environment variables -->
  <key>EnvironmentVariables</key>
  <dict>
    <!-- Load secrets from macOS Keychain instead -->
    <key>HOME</key>
    <string>/var/lib/alloy</string>
  </dict>

  <!-- macOS Sandbox restrictions -->
  <key>SandboxProfile</key>
  <string>com.grafana.alloy</string>

  <!-- Disable root privilege escalation -->
  <key>AbandonProcessGroup</key>
  <true/>

  <!-- Throttle restart attempts -->
```

```
  <key>ThrottleInterval</key>
  <integer>30</integer>

  <!-- Nice level — lower priority -->
  <key>Nice</key>
  <integer>5</integer>

  <!-- Resource limits -->
  <key>HardResourceLimits</key>
  <dict>
    <key>NumberOfFiles</key>
    <integer>65536</integer>
  </dict>
</dict>
</plist>


# Set correct permissions on plist
sudo chown root:wheel
/Library/LaunchDaemons/com.grafana.alloy.plist
sudo chmod 644 /Library/LaunchDaemons/com.grafana.alloy.plist

# Load the service
sudo launchctl load /Library/LaunchDaemons/com.grafana.alloy.plist

# Verify it is running as alloy user
ps aux | grep alloy
```

2.4 — macOS Keychain Integration for Secrets

```
# Store Alloy secrets in macOS Keychain instead of plaintext files
```

```
# Store a secret
security add-generic-password \
  -a "alloy" \
  -s "grafana-cloud-api-key" \
  -w "your-api-key-here" \
  -T /usr/local/bin/alloy

# Retrieve a secret (for use in wrapper script)
GRAFANA_API_KEY=$(security find-generic-password \
  -a "alloy" \
  -s "grafana-cloud-api-key" \
  -w)

# Create a wrapper script that loads secrets
sudo tee /usr/local/bin/alloy-start.sh << 'EOF'
#!/bin/bash
# Load secrets from Keychain
export GRAFANA_CLOUD_API_KEY=$(security \
  find-generic-password \
  -a "alloy" \
  -s "grafana-cloud-api-key" \
  -w 2>/dev/null)

export LOKI_URL=$(security \
  find-generic-password \
  -a "alloy" \
  -s "loki-url" \
  -w 2>/dev/null)

# Start Alloy
exec /usr/local/bin/alloy run \
```

```
  /etc/alloy/config.alloy \
  --server.http.listen-addr=127.0.0.1:12345 \
  "$@"
EOF

sudo chmod 750 /usr/local/bin/alloy-start.sh
sudo chown alloy:alloy /usr/local/bin/alloy-start.sh
```

2.5 — macOS Sandbox Profile

```
;; /etc/alloy/com.grafana.alloy.sb
;; macOS Sandbox profile for Grafana Alloy

(version 1)
(deny default)

;; Allow reading own configuration
(allow file-read* (subpath "/etc/alloy"))

;; Allow writing to data directory
(allow file-read* file-write* (subpath "/var/lib/alloy"))

;; Allow writing to log directory
(allow file-write* (subpath "/var/log/alloy"))

;; Allow network connections (outbound only)
(allow network-outbound)

;; Allow reading system libraries
(allow file-read*
  (subpath "/usr/lib")
```

```
  (subpath "/usr/local/lib")
  (subpath "/System/Library"))

;; Allow process operations
(allow process-fork)
(allow process-exec)

;; Allow signal handling
(allow signal (target self))

;; Deny access to sensitive system areas
(deny file-read*
  (subpath "/Users")
  (subpath "/private/etc/shadow")
  (subpath "/private/var/db"))
```

2.6 — macOS Specific Security Checks

```
# Verify Alloy binary signature
codesign --verify --verbose=4 /usr/local/bin/alloy

# Check Gatekeeper assessment
spctl --assess --verbose /usr/local/bin/alloy

# Verify no SUID/SGID bits
find /usr/local/bin/alloy -perm /6000 -type f

# Check for world-writable config files
find /etc/alloy -perm -o+w -type f

# Verify Alloy is not listening on all interfaces
```

```
lsof -i -n -P | grep alloy

# Check process is running as alloy user
ps aux | grep alloy | grep -v grep
# Should show: alloy ... /usr/local/bin/alloy

# Enable macOS Firewall
sudo /usr/libexec/ApplicationFirewall/socketfilterfw --
setglobalstate on

# Add Alloy to firewall (block inbound except localhost)
sudo /usr/libexec/ApplicationFirewall/socketfilterfw --add
/usr/local/bin/alloy
sudo /usr/libexec/ApplicationFirewall/socketfilterfw --blockapp
/usr/local/bin/alloy
```

---

3. Linux Hardening

3.1 — Dedicated Service Account

```
# Create system user with no login shell and no home directory
access
sudo useradd \
  --system \
  --no-create-home \
  --shell /usr/sbin/nologin \
  --comment "Grafana Alloy Service Account" \
  --home-dir /var/lib/alloy \
  alloy
```

```
# Create required directories
sudo mkdir -p /etc/alloy/secrets
sudo mkdir -p /var/lib/alloy
sudo mkdir -p /var/log/alloy

# Set ownership and permissions
sudo chown -R alloy:alloy /etc/alloy
sudo chown -R alloy:alloy /var/lib/alloy
sudo chown -R alloy:alloy /var/log/alloy

sudo chmod 750 /etc/alloy
sudo chmod 640 /etc/alloy/config.alloy
sudo chmod 700 /etc/alloy/secrets
sudo chmod 750 /var/lib/alloy
sudo chmod 750 /var/log/alloy

# Verify user
id alloy
# Should show: uid=999(alloy) gid=999(alloy) groups=999(alloy)
```

3.2 — Systemd Service Hardening

```
# /etc/systemd/system/alloy.service
# Hardened systemd service unit for Grafana Alloy

[Unit]
Description=Grafana Alloy
Documentation=https://grafana.com/docs/alloy/latest/
After=network-online.target
Wants=network-online.target
StartLimitIntervalSec=60
```

```
StartLimitBurst=3

[Service]
# Identity
User=alloy
Group=alloy

# Process execution
Type=simple
ExecStart=/usr/local/bin/alloy run \
  /etc/alloy/config.alloy \
  --server.http.listen-addr=127.0.0.1:12345 \
  --disable-reporting=true \
  --stability.level=generally-available

ExecReload=/bin/kill -HUP $MAINPID
Restart=on-failure
RestartSec=10s

# Load secrets from environment file
EnvironmentFile=-/etc/alloy/alloy-secrets.env

# Filesystem Restrictions
ReadWritePaths=/var/lib/alloy /var/log/alloy
ReadOnlyPaths=/etc/alloy
ProtectHome=true
ProtectSystem=strict
PrivateTmp=true
ProcSubset=pid
ProtectProc=invisible

# Privilege Restrictions
```

```
NoNewPrivileges=true
CapabilityBoundingSet=
AmbientCapabilities=
RestrictSUIDSGID=true
RestrictRealtime=true

# Namespace Restrictions
PrivateUsers=true
ProtectKernelTunables=true
ProtectKernelModules=true
ProtectKernelLogs=true
ProtectClock=true
ProtectHostname=true
ProtectControlGroups=true

# System Call Filtering (Seccomp)
SystemCallFilter=@system-service
SystemCallFilter=~@privileged @resources @obsolete
SystemCallErrorNumber=EPERM
SystemCallArchitectures=native

# Resource Limits
LimitNOFILE=65536
MemoryMax=1G
MemoryHigh=768M
CPUQuota=200%
LimitCORE=0

# Logging
StandardOutput=journal
StandardError=journal
SyslogIdentifier=alloy
```

```
# Working Directory
WorkingDirectory=/var/lib/alloy

[Install]
WantedBy=multi-user.target


# Apply the hardened service
sudo systemctl daemon-reload
sudo systemctl enable alloy
sudo systemctl start alloy

# Verify security settings applied
sudo systemd-analyze security alloy
# Expected: Security Rating should be SAFE or better
# Score should be 0.0-4.0 (lower is more secure)
```

3.3 — Linux Capabilities Hardening

```
# Verify Alloy binary has no SUID bit
stat /usr/local/bin/alloy
# Expected: Access: (0755/-rwxr-xr-x)

# Verify no capabilities set on binary
getcap /usr/local/bin/alloy
# Expected: no output (no capabilities)

# Remove any capabilities that may have been set
sudo setcap -r /usr/local/bin/alloy 2>/dev/null || true
```

```
# Verify alloy process capabilities at runtime
cat /proc/$(pgrep alloy)/status | grep Cap
# CapPrm and CapEff should be 0000000000000000
```

3.4 — AppArmor Profile (Ubuntu/Debian)

```
# Create AppArmor profile for Alloy
sudo tee /etc/apparmor.d/usr.local.bin.alloy << 'EOF'
#include <tunables/global>

/usr/local/bin/alloy {
  #include <abstractions/base>
  #include <abstractions/nameservice>
  #include <abstractions/openssl>
  #include <abstractions/ssl_certs>

  # Binary execution
  /usr/local/bin/alloy mr,

  # Configuration files — read only
  /etc/alloy/ r,
  /etc/alloy/** r,

  # Data directory — read/write
  /var/lib/alloy/ rw,
  /var/lib/alloy/** rw,

  # Log directory — write only
  /var/log/alloy/ rw,
  /var/log/alloy/** rw,
```

```
  # Temporary directory
  /tmp/alloy-** rw,

  # System libraries — read only
  /usr/lib/** mr,
  /usr/local/lib/** mr,
  /lib/** mr,

  # Proc filesystem — own process only
  @{PROC}/@{pid}/fd/ r,
  @{PROC}/@{pid}/status r,
  @{PROC}/@{pid}/net/ r,

  # Network access
  network tcp,
  network udp,

  # DNS resolution
  /etc/hosts r,
  /etc/resolv.conf r,
  /etc/nsswitch.conf r,

  # Deny sensitive paths
  deny /etc/shadow r,
  deny /etc/sudoers r,
  deny /root/** rw,
  deny /home/** rw,
  deny @{PROC}/*/mem r,
  deny @{PROC}/sysrq-trigger rw,
}
EOF
```

```
# Load the AppArmor profile
sudo apparmor_parser -r /etc/apparmor.d/usr.local.bin.alloy

# Verify profile is active
sudo aa-status | grep alloy

# Enable enforcement mode
sudo aa-enforce /usr/local/bin/alloy
```

3.5 — SELinux Policy (RHEL/CentOS/Fedora)

```
# Check SELinux status
getenforce
# Should be: Enforcing

# Create SELinux policy module for Alloy
sudo tee alloy.te << 'EOF'
module alloy 1.0;

require {
  type init_t;
  type unconfined_service_t;
  class file { read write execute };
  class dir { read write search };
  class tcp_socket { connect create };
  class udp_socket { connect create };
}

# Allow Alloy to read its configuration
allow unconfined_service_t var_t:file { read write };
```

```
# Allow network connections
allow unconfined_service_t self:tcp_socket { connect create };
EOF

# Compile and install policy
checkmodule -M -m -o alloy.mod alloy.te
semodule_package -o alloy.pp -m alloy.mod
sudo semodule -i alloy.pp

# Label Alloy files correctly
sudo semanage fcontext -a -t bin_t "/usr/local/bin/alloy"
sudo semanage fcontext -a -t etc_t "/etc/alloy(/.*)?"
sudo restorecon -Rv /usr/local/bin/alloy
sudo restorecon -Rv /etc/alloy/

# Verify labels
ls -Z /usr/local/bin/alloy
ls -Z /etc/alloy/
```

3.6 — Linux File Integrity Monitoring

```
# Install AIDE (Advanced Intrusion Detection Environment)
sudo apt-get install aide  # Debian/Ubuntu
# or
sudo yum install aide      # RHEL/CentOS

# Add Alloy paths to AIDE configuration
sudo tee /etc/aide/aide.conf.d/99-alloy << 'EOF'
# Monitor Alloy binary
/usr/local/bin/alloy FIPSR
```

```
# Monitor Alloy configuration
/etc/alloy FIPSR
/etc/alloy/config.alloy FIPSR

# Monitor Alloy service file
/etc/systemd/system/alloy.service FIPSR
EOF

# Initialise AIDE database
sudo aide --init
sudo mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db

# Schedule daily AIDE check
sudo tee /etc/cron.daily/aide-alloy-check << 'EOF'
#!/bin/bash
aide --check | mail -s "AIDE Alloy Check" security@company.com
EOF
sudo chmod 750 /etc/cron.daily/aide-alloy-check
```

3.7 — Linux Secrets Management

```
# Option A — systemd credentials (systemd 250+)
# Encrypt secrets with systemd-creds

echo -n "your-api-key" | \
  systemd-creds encrypt \
  --name=grafana-cloud-api-key - \
  /etc/alloy/credentials/grafana-cloud-api-key.cred

# Reference in systemd service:
# [Service]
```

```
# LoadCredential=grafana-cloud-api-key:\
#   /etc/alloy/credentials/grafana-cloud-api-key.cred
# Environment=GRAFANA_CLOUD_API_KEY=%d/grafana-cloud-api-key

# Option B — Encrypted environment file
sudo tee /etc/alloy/alloy-secrets.env << 'EOF'
GRAFANA_CLOUD_API_KEY=your-api-key
LOKI_URL=https://logs-prod.grafana.net
PROMETHEUS_URL=https://prometheus-prod.grafana.net
EOF

# Restrict permissions
sudo chmod 600 /etc/alloy/alloy-secrets.env
sudo chown alloy:alloy /etc/alloy/alloy-secrets.env

# Option C — HashiCorp Vault Agent (recommended)
# See Section 8 for Vault integration
```

---

4. Windows Hardening

4.1 — Dedicated Service Account

```
# Run as Administrator

# Create a local service account
$SecurePassword = ConvertTo-SecureString `
  "$(New-Guid)$(New-Guid)" `
  -AsPlainText -Force

New-LocalUser `
```

```
  -Name "alloy" `
  -Password $SecurePassword `
  -Description "Grafana Alloy Service Account" `
  -PasswordNeverExpires $true `
  -UserMayNotChangePassword $true `
  -AccountNeverExpires

# Deny interactive logon
$SID = (Get-LocalUser -Name "alloy").SID

# Add to Log on as a service right
$TempFile = [System.IO.Path]::GetTempFileName()
secedit /export /cfg $TempFile
$Config = Get-Content $TempFile
$Config = $Config -replace `
  "(SeServiceLogonRight = .*)", `
  "`$1,*$($SID.Value)"
$Config | Set-Content $TempFile
secedit /configure /db secedit.sdb /cfg $TempFile
Remove-Item $TempFile

# Deny interactive login
$TempFile = [System.IO.Path]::GetTempFileName()
secedit /export /cfg $TempFile
$Config = Get-Content $TempFile
$Config = $Config -replace `
  "(SeDenyInteractiveLogonRight = .*)", `
  "`$1,*$($SID.Value)"
$Config | Set-Content $TempFile
secedit /configure /db secedit.sdb /cfg $TempFile
Remove-Item $TempFile
```

```
Write-Host "Service account 'alloy' created successfully"
```

4.2 — File System Permissions

```
# Create required directories
$Directories = @(
  "C:\Program Files\GrafanaAlloy",
  "C:\ProgramData\GrafanaAlloy\config",
  "C:\ProgramData\GrafanaAlloy\data",
  "C:\ProgramData\GrafanaAlloy\logs",
  "C:\ProgramData\GrafanaAlloy\secrets"
)

foreach ($Dir in $Directories) {
  New-Item -ItemType Directory -Force -Path $Dir
}

# Helper function to set strict ACLs
function Set-StrictACL {
  param(
    [string]$Path,
    [string]$Identity,
    [string]$Rights,
    [string]$Type = "Allow"
  )
  $ACL = Get-Acl $Path
  $ACL.SetAccessRuleProtection($true, $false)
  $ACL.Access | ForEach-Object { $ACL.RemoveAccessRule($_) | Out-
Null }

  $SystemRule = New-Object
```

```
System.Security.AccessControl.FileSystemAccessRule(
    "NT AUTHORITY\SYSTEM", "FullControl",
    "ContainerInherit,ObjectInherit", "None", "Allow")
  $ACL.AddAccessRule($SystemRule)

  $AdminRule = New-Object
System.Security.AccessControl.FileSystemAccessRule(
    "BUILTIN\Administrators", "FullControl",
    "ContainerInherit,ObjectInherit", "None", "Allow")
  $ACL.AddAccessRule($AdminRule)

  if ($Identity -and $Rights) {
    $IdentityRule = New-Object
System.Security.AccessControl.FileSystemAccessRule(
      $Identity, $Rights,
      "ContainerInherit,ObjectInherit", "None", $Type)
    $ACL.AddAccessRule($IdentityRule)
  }
  Set-Acl -Path $Path -AclObject $ACL
  Write-Host "ACL set on: $Path"
}

# Apply permissions
Set-StrictACL -Path "C:\ProgramData\GrafanaAlloy\config" -Identity
"alloy" -Rights "ReadAndExecute"
Set-StrictACL -Path "C:\ProgramData\GrafanaAlloy\data" -Identity
"alloy" -Rights "Modify"
Set-StrictACL -Path "C:\ProgramData\GrafanaAlloy\logs" -Identity
"alloy" -Rights "Modify"
Set-StrictACL -Path "C:\ProgramData\GrafanaAlloy\secrets" -
Identity "alloy" -Rights "ReadAndExecute"
```

```
# Verify
Get-Acl "C:\ProgramData\GrafanaAlloy\config" | Format-List
```

4.3 — Windows Service Hardening

```
# Install Alloy as a Windows Service with hardened settings
$BinaryPath = `
  '"C:\Program Files\GrafanaAlloy\alloy.exe" run ' + `
  '"C:\ProgramData\GrafanaAlloy\config\config.alloy" ' + `
  '--server.http.listen-addr=127.0.0.1:12345 ' + `
  '--disable-reporting=true ' + `
  '--stability.level=generally-available'

New-Service `
  -Name "GrafanaAlloy" `
  -BinaryPathName $BinaryPath `
  -DisplayName "Grafana Alloy" `
  -Description "Grafana Alloy telemetry collector" `
  -StartupType Automatic `
  -Credential (Get-Credential ".\alloy")

# Configure service failure recovery
sc.exe failure GrafanaAlloy `
  reset= 86400 `
  actions= restart/30000/restart/60000/restart/120000

# Harden service permissions
$SDDL = "D:(A;;CCLCSWRPWPDTLOCRRC;;;SY)" + `
        "(A;;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;BA)" + `
        "(A;;CCLCSWLOCRRC;;;IU)" + `
        "(A;;CCLCSWLOCRRC;;;SU)"
```

```
sc.exe sdset GrafanaAlloy $SDDL

# Verify service is running as alloy user
Get-WmiObject Win32_Service | `
  Where-Object { $_.Name -eq "GrafanaAlloy" } | `
  Select-Object Name, StartName, State

Start-Service GrafanaAlloy
```

4.4 — Windows Credential Manager Integration

```
# Store Alloy secrets in Windows Credential Manager
Install-Module -Name CredentialManager -Force

New-StoredCredential `
  -Target "GrafanaAlloy/CloudApiKey" `
  -UserName "alloy" `
  -Password "your-api-key" `
  -Type Generic `
  -Persist LocalMachine

New-StoredCredential `
  -Target "GrafanaAlloy/LokiUrl" `
  -UserName "alloy" `
  -Password "https://logs-prod.grafana.net" `
  -Type Generic `
  -Persist LocalMachine

# Create a script to retrieve secrets at service start
$ScriptContent = @'
$ApiKey = (Get-StoredCredential `
```

```
  -Target
"GrafanaAlloy/CloudApiKey").GetNetworkCredential().Password
$LokiUrl = (Get-StoredCredential `
  -Target "GrafanaAlloy/LokiUrl").GetNetworkCredential().Password

[Environment]::SetEnvironmentVariable("GRAFANA_CLOUD_API_KEY",
$ApiKey, "Process")
[Environment]::SetEnvironmentVariable("LOKI_URL", $LokiUrl,
"Process")

& "C:\Program Files\GrafanaAlloy\alloy.exe" run `
  "C:\ProgramData\GrafanaAlloy\config\config.alloy"
'@

$ScriptContent | Set-Content "C:\Program Files\GrafanaAlloy\start-
alloy.ps1"
```

4.5 — Windows Firewall Rules

```
# Allow Alloy outbound HTTPS (to Grafana Cloud)
New-NetFirewallRule `
  -DisplayName "Grafana Alloy - Outbound HTTPS" `
  -Direction Outbound -Protocol TCP -RemotePort 443 `
  -Program "C:\Program Files\GrafanaAlloy\alloy.exe" `
  -Action Allow -Profile Any

# Allow Alloy outbound for Prometheus remote write
New-NetFirewallRule `
  -DisplayName "Grafana Alloy - Remote Write" `
  -Direction Outbound -Protocol TCP -RemotePort 9090 `
  -Program "C:\Program Files\GrafanaAlloy\alloy.exe" `
```

```
  -Action Allow -Profile Any

# Block all inbound to Alloy from external
New-NetFirewallRule `
  -DisplayName "Grafana Alloy - Block Inbound" `
  -Direction Inbound -Protocol TCP -LocalPort 12345 `
  -RemoteAddress "!127.0.0.1" `
  -Program "C:\Program Files\GrafanaAlloy\alloy.exe" `
  -Action Block -Profile Any

# Allow OTLP only from local applications
New-NetFirewallRule `
  -DisplayName "Grafana Alloy - OTLP Local Only" `
  -Direction Inbound -Protocol TCP -LocalPort 4317,4318 `
  -RemoteAddress "127.0.0.1" `
  -Program "C:\Program Files\GrafanaAlloy\alloy.exe" `
  -Action Allow -Profile Any

# Verify rules
Get-NetFirewallRule | `
  Where-Object { $_.DisplayName -like "Grafana Alloy*" } | `
  Select-Object DisplayName, Direction, Action, Enabled
```

4.6 — Windows Event Log & Audit Policy

```
# Enable auditing for Alloy files and directories
auditpol /set /subcategory:"Process Creation" /success:enable
/failure:enable
auditpol /set /subcategory:"File System" /success:enable
/failure:enable
auditpol /set /subcategory:"Logon" /success:enable /failure:enable
```

```
# Add audit ACE to Alloy config directory
$ACL = Get-Acl "C:\ProgramData\GrafanaAlloy\config"
$AuditRule = New-Object
System.Security.AccessControl.FileSystemAuditRule(
  "Everyone", "Write,Delete,ChangePermissions",
  "ContainerInherit,ObjectInherit", "None", "Failure")
$ACL.AddAuditRule($AuditRule)
Set-Acl -Path "C:\ProgramData\GrafanaAlloy\config" -AclObject $ACL

# Set up Windows Event Forwarding for Alloy events
wecutil qc /q
Write-Host "Audit policy configured for Grafana Alloy"
```

---

5. Kubernetes Hardening

5.1 — Namespace with Pod Security Standards

```
# namespace.yaml
apiVersion: v1
kind: Namespace
metadata:
  name: alloy
  labels:
    app.kubernetes.io/name: alloy
    pod-security.kubernetes.io/enforce: restricted
    pod-security.kubernetes.io/enforce-version: latest
    pod-security.kubernetes.io/audit: restricted
    pod-security.kubernetes.io/audit-version: latest
    pod-security.kubernetes.io/warn: restricted
```

```
    pod-security.kubernetes.io/warn-version: latest
```

5.2 — Kubernetes RBAC — Minimum Permissions

```
# rbac.yaml
apiVersion: v1
kind: ServiceAccount
metadata:
  name: alloy
  namespace: alloy
  labels:
    app.kubernetes.io/name: alloy
automountServiceAccountToken: false
---
apiVersion: rbac.authorization.k8s.io/v1
kind: ClusterRole
metadata:
  name: alloy
  labels:
    app.kubernetes.io/name: alloy
rules:
  - apiGroups: [""]
    resources: [nodes, nodes/proxy, nodes/metrics, services,
endpoints, pods, events]
    verbs: ["get", "list", "watch"]
  - apiGroups: [""]
    resources: [configmaps]
    verbs: ["get"]
  - apiGroups: ["discovery.k8s.io"]
    resources: [endpointslices]
    verbs: ["get", "list", "watch"]
```

```yaml
  - nonResourceURLs: ["/metrics", "/metrics/cadvisor"]
    verbs: ["get"]
  - apiGroups: ["monitoring.coreos.com"]
    resources: [servicemonitors, podmonitors, probes]
    verbs: ["get", "list", "watch"]
---
apiVersion: rbac.authorization.k8s.io/v1
kind: ClusterRoleBinding
metadata:
  name: alloy
  labels:
    app.kubernetes.io/name: alloy
roleRef:
  apiGroup: rbac.authorization.k8s.io
  kind: ClusterRole
  name: alloy
subjects:
  - kind: ServiceAccount
    name: alloy
    namespace: alloy
```

5.3 — Hardened Deployment

```yaml
# deployment.yaml
apiVersion: apps/v1
kind: Deployment
metadata:
  name: alloy
  namespace: alloy
  labels:
    app.kubernetes.io/name: alloy
```

```
    app.kubernetes.io/version: "v1.x.x"
spec:
  replicas: 2
  selector:
    matchLabels:
      app.kubernetes.io/name: alloy
  strategy:
    type: RollingUpdate
    rollingUpdate:
      maxSurge: 1
      maxUnavailable: 0
  template:
    metadata:
      labels:
        app.kubernetes.io/name: alloy
      annotations:
        checksum/config: "{{ include config.alloy | sha256sum }}"
        container.apparmor.security.beta.kubernetes.io/alloy:
runtime/default
    spec:
      serviceAccountName: alloy
      automountServiceAccountToken: true

      securityContext:
        runAsNonRoot: true
        runAsUser: 10001
        runAsGroup: 10001
        fsGroup: 10001
        seccompProfile:
          type: RuntimeDefault
        supplementalGroups: []
```

```
      topologySpreadConstraints:
        - maxSkew: 1
          topologyKey: kubernetes.io/hostname
          whenUnsatisfiable: DoNotSchedule
          labelSelector:
            matchLabels:
              app.kubernetes.io/name: alloy

      containers:
        - name: alloy
          image: grafana/alloy:v1.x.x@sha256:<digest>
          imagePullPolicy: IfNotPresent
          args:
            - run
            - /etc/alloy/config.alloy
            - --server.http.listen-addr=0.0.0.0:12345
            - --disable-reporting=true
            - --stability.level=generally-available
            - --storage.path=/var/lib/alloy/data

          securityContext:
            runAsNonRoot: true
            runAsUser: 10001
            runAsGroup: 10001
            readOnlyRootFilesystem: true
            allowPrivilegeEscalation: false
            capabilities:
              drop: ["ALL"]
            seccompProfile:
              type: RuntimeDefault

          ports:
```

```
            - name: http-metrics
              containerPort: 12345
              protocol: TCP
            - name: otlp-grpc
              containerPort: 4317
              protocol: TCP
            - name: otlp-http
              containerPort: 4318
              protocol: TCP

          resources:
            requests:
              cpu: 100m
              memory: 256Mi
            limits:
              cpu: 1000m
              memory: 1Gi

          livenessProbe:
            httpGet:
              path: /-/healthy
              port: http-metrics
            initialDelaySeconds: 15
            periodSeconds: 20
            timeoutSeconds: 5
            failureThreshold: 3

          readinessProbe:
            httpGet:
              path: /-/ready
              port: http-metrics
            initialDelaySeconds: 5
```

```
            periodSeconds: 10
            timeoutSeconds: 3
            failureThreshold: 3

          env:
            - name: HOSTNAME
              valueFrom:
                fieldRef:
                  fieldPath: spec.nodeName
          envFrom:
            - secretRef:
                name: alloy-credentials

          volumeMounts:
            - name: config
              mountPath: /etc/alloy
              readOnly: true
            - name: data
              mountPath: /var/lib/alloy/data
            - name: tmp
              mountPath: /tmp
            - name: varlog
              mountPath: /var/log/pods
              readOnly: true
            - name: kube-api-access
              mountPath:
/var/run/secrets/kubernetes.io/serviceaccount
              readOnly: true

      volumes:
        - name: config
          configMap:
```

```
            name: alloy-config
            defaultMode: 0440
        - name: data
          emptyDir: {}
        - name: tmp
          emptyDir: {}
        - name: varlog
          hostPath:
            path: /var/log/pods
            type: DirectoryOrCreate
        - name: kube-api-access
          projected:
            defaultMode: 0444
            sources:
              - serviceAccountToken:
                  expirationSeconds: 3607
                  path: token
              - configMap:
                  name: kube-root-ca.crt
                  items:
                    - key: ca.crt
                      path: ca.crt
              - downwardAPI:
                  items:
                    - path: namespace
                      fieldRef:
                        apiVersion: v1
                        fieldPath: metadata.namespace

      nodeSelector:
        kubernetes.io/os: linux
      terminationGracePeriodSeconds: 60
```

5.4 — Network Policy — Zero Trust

```yaml
# Default deny all in alloy namespace
apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  name: default-deny-all
  namespace: alloy
spec:
  podSelector: {}
  policyTypes: [Ingress, Egress]
---
# Alloy-specific network policy
apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  name: alloy
  namespace: alloy
spec:
  podSelector:
    matchLabels:
      app.kubernetes.io/name: alloy
  policyTypes: [Ingress, Egress]

  ingress:
    - from:
        - namespaceSelector:
            matchLabels:
              kubernetes.io/metadata.name: monitoring
          podSelector:
```

```
            matchLabels:
              app.kubernetes.io/name: prometheus
      ports:
        - port: 12345
          protocol: TCP
    - from:
        - namespaceSelector:
            matchLabels:
              alloy-otlp-allowed: "true"
      ports:
        - port: 4317
          protocol: TCP
        - port: 4318
          protocol: TCP

  egress:
    - to:
        - namespaceSelector: {}
          podSelector:
            matchLabels:
              k8s-app: kube-dns
      ports:
        - port: 53
          protocol: UDP
        - port: 53
          protocol: TCP
    - to:
        - ipBlock:
            cidr: <kubernetes-api-server-cidr>/32
      ports:
        - port: 443
          protocol: TCP
```

```
        - port: 6443
          protocol: TCP
    - to:
        - ipBlock:
            cidr: 0.0.0.0/0
            except: [10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16]
      ports:
        - port: 443
          protocol: TCP
```

5.5 — Secrets Management in Kubernetes

Option A — Kubernetes Secret (baseline):

```
apiVersion: v1
kind: Secret
metadata:
  name: alloy-credentials
  namespace: alloy
  labels:
    app.kubernetes.io/name: alloy
type: Opaque
stringData:
  GRAFANA_CLOUD_API_KEY: ""
  LOKI_URL: ""
  PROMETHEUS_URL: ""
  TEMPO_URL: ""
```

Option B — External Secrets Operator (recommended):

```
apiVersion: external-secrets.io/v1beta1
```

```yaml
kind: ExternalSecret
metadata:
  name: alloy-credentials
  namespace: alloy
spec:
  refreshInterval: 1h
  secretStoreRef:
    name: vault-backend
    kind: ClusterSecretStore
  target:
    name: alloy-credentials
    creationPolicy: Owner
    deletionPolicy: Retain
    template:
      type: Opaque
      engineVersion: v2
  data:
    - secretKey: GRAFANA_CLOUD_API_KEY
      remoteRef:
        key: secret/alloy/grafana-cloud
        property: api-key
    - secretKey: LOKI_URL
      remoteRef:
        key: secret/alloy/grafana-cloud
        property: loki-url
    - secretKey: PROMETHEUS_URL
      remoteRef:
        key: secret/alloy/grafana-cloud
        property: prometheus-url
    - secretKey: TEMPO_URL
      remoteRef:
        key: secret/alloy/grafana-cloud
```

```
        property: tempo-url
```

5.6 — Pod Disruption Budget & Security Policies

```
# pdb.yaml
apiVersion: policy/v1
kind: PodDisruptionBudget
metadata:
  name: alloy
  namespace: alloy
spec:
  minAvailable: 1
  selector:
    matchLabels:
      app.kubernetes.io/name: alloy
```

Kyverno Policy — Enforce security standards on Alloy pods:

```
apiVersion: kyverno.io/v1
kind: Policy
metadata:
  name: alloy-security-policy
  namespace: alloy
spec:
  validationFailureAction: enforce
  background: true
  rules:
    - name: require-non-root
      match:
        any:
```

```
          - resources:
              kinds: ["Pod"]
              namespaces: ["alloy"]
      validate:
        message: "Alloy pods must run as non-root"
        pattern:
          spec:
            securityContext:
              runAsNonRoot: true
            containers:
              - name: "*"
                securityContext:
                  runAsNonRoot: true
                  allowPrivilegeEscalation: false
                  readOnlyRootFilesystem: true
                  capabilities:
                    drop: ["ALL"]
    - name: require-resource-limits
      match:
        any:
          - resources:
              kinds: ["Pod"]
              namespaces: ["alloy"]
      validate:
        message: "Alloy pods must have resource limits"
        pattern:
          spec:
            containers:
              - name: "*"
                resources:
                  limits:
                    memory: "?*"
```

```
                    cpu: "?*"
                  requests:
                    memory: "?*"
                    cpu: "?*"
    - name: disallow-privileged
      match:
        any:
          - resources:
              kinds: ["Pod"]
              namespaces: ["alloy"]
      validate:
        message: "Alloy pods must not be privileged"
        pattern:
          spec:
            containers:
              - name: "*"
                =(securityContext):
                  =(privileged): false
```

5.7 — Falco Runtime Security Rules

```
# Custom Falco rules for monitoring Alloy runtime behaviour

- rule: Alloy Unexpected File Access
  desc: Alloy pod accessing files outside expected paths
  condition: >
    spawned_process and
    container.image.repository = "grafana/alloy" and
    (fd.name startswith "/etc/shadow" or
     fd.name startswith "/etc/sudoers" or
     fd.name startswith "/root" or
```

```
     fd.name startswith "/home")
  output: >
    Alloy accessing unexpected file
    (user=%user.name file=%fd.name container=%container.id
image=%container.image)
  priority: WARNING
  tags: [alloy, security]

- rule: Alloy Unexpected Network Connection
  desc: Alloy making unexpected outbound connection
  condition: >
    outbound and
    container.image.repository = "grafana/alloy" and
    not fd.sport in (443, 4317, 4318, 9090) and
    not fd.sip in (allowed_ips)
  output: >
    Alloy unexpected outbound connection
    (destination=%fd.rip:%fd.rport container=%container.id)
  priority: WARNING
  tags: [alloy, network, security]

- rule: Alloy Process Spawning Shell
  desc: Alloy container spawning unexpected shell
  condition: >
    spawned_process and
    container.image.repository = "grafana/alloy" and
    proc.name in (shell_binaries)
  output: >
    Alloy spawning shell (shell=%proc.name
container=%container.id)
  priority: CRITICAL
  tags: [alloy, security]
```

```
- rule: Alloy Config Modified at Runtime
  desc: Alloy configuration modified while running
  condition: >
    open_write and
    container.image.repository = "grafana/alloy" and
    fd.name startswith "/etc/alloy"
  output: >
    Alloy config file modified (file=%fd.name user=%user.name
container=%container.id)
  priority: ERROR
  tags: [alloy, config, security]
```

---

6. Configuration Security

6.1 — Secure Alloy Configuration Template

```
// config.alloy — Hardened Production Configuration

// Logging — JSON format for SIEM integration
logging {
  level  = "warn"
  format = "json"
  write_to = [loki.write.audit_logs.receiver]
}

// Disable internal tracing (reduces attack surface)
tracing {
  sampling_fraction = 0.0
}
```

```
// TLS for all OTLP receivers
otelcol.receiver.otlp "secured" {
  grpc {
    endpoint = "0.0.0.0:4317"
    tls {
      cert_file      = "/etc/alloy/tls/tls.crt"
      key_file       = "/etc/alloy/tls/tls.key"
      min_version    = "TLS13"
      client_ca_file = "/etc/alloy/tls/ca.crt"
    }
  }
  http {
    endpoint = "0.0.0.0:4318"
    tls {
      cert_file      = "/etc/alloy/tls/tls.crt"
      key_file       = "/etc/alloy/tls/tls.key"
      min_version    = "TLS13"
      client_ca_file = "/etc/alloy/tls/ca.crt"
    }
  }
  output {
    metrics = [otelcol.processor.batch.default.input]
    logs    = [otelcol.processor.batch.default.input]
    traces  = [otelcol.processor.batch.default.input]
  }
}

// TLS for remote write (Prometheus)
prometheus.remote_write "grafana_cloud" {
  endpoint {
    url = env("PROMETHEUS_URL")
```

```
    basic_auth {
      username = env("PROMETHEUS_USERNAME")
      password = env("GRAFANA_CLOUD_API_KEY")
    }
    tls_config {
      insecure_skip_verify = false
      min_version          = "TLS12"
    }
    queue_config {
      capacity             = 10000
      max_shards           = 50
      max_samples_per_send = 2000
      batch_send_deadline  = "5s"
      max_retries          = 5
      min_backoff          = "30ms"
      max_backoff          = "5s"
    }
  }
  wal {
    truncate_frequency = "2h"
    max_keepalive_time = "8h"
    min_keepalive_time = "1h"
  }
}

// TLS for Loki write
loki.write "grafana_cloud" {
  endpoint {
    url = env("LOKI_URL")
    basic_auth {
      username = env("LOKI_USERNAME")
      password = env("GRAFANA_CLOUD_API_KEY")
```

```
    }
    tls_config {
      insecure_skip_verify = false
      min_version          = "TLS12"
    }
  }
}

// Sanitise labels — remove potentially sensitive label values
prometheus.relabel "sanitise_labels" {
  rule {
    action = "labeldrop"
    regex  = "password|secret|token|key|credential"
  }
  rule {
    target_label = "cluster"
    replacement  = env("CLUSTER_NAME")
  }
  rule {
    target_label = "environment"
    replacement  = env("ENVIRONMENT")
  }
  forward_to = [prometheus.remote_write.grafana_cloud.receiver]
}
```

6.2 — Sensitive Data Scrubbing

```
// Scrub sensitive data from logs before shipping

loki.process "scrub_sensitive_data" {
  stage.replace {
```

```
    expression = "(password|passwd|pwd)=\\S+"
    replace    = "$1=REDACTED"
  }
  stage.replace {
    expression = "(api[_-]?key|apikey)=\\S+"
    replace    = "$1=REDACTED"
  }
  stage.replace {
    expression = "(token|bearer)\\s+[A-Za-z0-9\\-_\\.]+"
    replace    = "$1 REDACTED"
  }
  stage.replace {
    expression = "(Authorization|authorization):\\s*\\S+"
    replace    = "$1: REDACTED"
  }
  // Mask credit card numbers (PCI DSS)
  stage.replace {
    expression = "\\b\\d{4}[\\s\\-]?\\d{4}[\\s\\-]?\\d{4}[\\s\\-
]?\\d{4}\\b"
    replace    = "CARD-REDACTED"
  }
  forward_to = [loki.write.grafana_cloud.receiver]
}
```

---

7. Network Security

7.1 — TLS Certificate Management

```
# Generate self-signed certificates for internal use
# (Use cert-manager or your PKI for production)
```

```
# Create CA
openssl genrsa -out ca.key 4096
openssl req -new -x509 -key ca.key -sha256 \
  -subj "/CN=Alloy-CA" -days 365 -out ca.crt

# Create Alloy server certificate
openssl genrsa -out tls.key 4096
openssl req -new -key tls.key \
  -subj "/CN=alloy.internal.company.com" -out tls.csr

# Sign with CA
openssl x509 -req -in tls.csr -CA ca.crt -CAkey ca.key \
  -CAcreateserial -out tls.crt -days 365 -sha256 \
  -extfile <(printf
"subjectAltName=DNS:alloy.internal.company.com,DNS:localhost,IP:12
7.0.0.1")

# Verify certificate
openssl verify -CAfile ca.crt tls.crt

# Set permissions
chmod 640 tls.key tls.crt ca.crt
chown alloy:alloy tls.key tls.crt ca.crt
```

7.2 — Allowed Outbound Endpoints

Document and restrict outbound connections to only these required endpoints:

Grafana Cloud:

Endpoint	Purpose
logs-prod-eu-west-0.grafana.net:443	Loki
prometheus-prod-01-eu-west-0.grafana.net:443	Mimir
tempo-prod-04-eu-west-0.grafana.net:443	Tempo

Internal:

Endpoint	Purpose
kubernetes-api-server:443	Kubernetes service discovery
internal-prometheus:9090	Scraping
kube-dns:53	DNS

---

8. Credential & Secret Management

8.1 — HashiCorp Vault Integration (All Platforms)

Alloy Configuration (reference environment variables populated by Vault):

```
prometheus.remote_write "secure" {
  endpoint {
    url = env("PROMETHEUS_REMOTE_WRITE_URL")
    basic_auth {
      username = env("PROMETHEUS_USERNAME")
      password = env("PROMETHEUS_PASSWORD")
    }
  }
}
```

Vault Agent Configuration (for non-Kubernetes deployments):

```
# vault-agent-config.hcl
vault {
  address = "https://vault.internal.company.com:8200"
}

auto_auth {
  method "approle" {
    config = {
      role_id_file_path                    = "/etc/vault/role-id"
      secret_id_file_path                  = "/etc/vault/secret-id"
      remove_secret_id_file_after_reading = true
    }
  }
  sink "file" {
    config = {
      path = "/tmp/vault-token"
      mode = 0640
    }
  }
}
```

```
template {
  source      = "/etc/alloy/alloy-secrets.ctmpl"
  destination = "/etc/alloy/alloy-secrets.env"
  perms       = 0640
  command     = "systemctl reload alloy"
}
```

Vault Template:

```
{{ with secret "secret/alloy/grafana-cloud" }}
GRAFANA_CLOUD_API_KEY={{ .Data.data.api_key }}
PROMETHEUS_URL={{ .Data.data.prometheus_url }}
LOKI_URL={{ .Data.data.loki_url }}
TEMPO_URL={{ .Data.data.tempo_url }}
{{ end }}
```

8.2 — Secret Rotation Policy

Secret Type	Rotation Frequency
Grafana Cloud API Tokens	Every 90 days
TLS Certificates	Every 365 days (or via cert-manager auto)
Vault AppRole Secret IDs	Every 24 hours (automatic)

Secret Type	Rotation Frequency
Service Account Tokens	Every 90 days
Database Credentials	Every 90 days

Rotation Process:

1. Generate new credential
2. Update in secrets manager
3. Verify Alloy picks up new value (via agent auto-reload or manual restart)
4. Revoke old credential
5. Document rotation in audit log

---

9. TLS Hardening

9.1 — Minimum TLS Standards

Apply to **all** Alloy connections:

Setting	Requirement
Minimum TLS version	TLS 1.2 (TLS 1.3 preferred)
insecure_skip_verify	false — always

Setting	Requirement
Self-signed in production	Not permitted (use internal CA)

Allowed cipher suites (TLS 1.2):

- TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
- TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
- TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256
- TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384

Explicitly disabled:

- SSL 2.0 / 3.0
- TLS 1.0 / 1.1
- RC4 cipher suites
- DES / 3DES
- MD5 signatures

---

10. Audit & Monitoring

10.1 — Alloy Self-Monitoring

Monitor these security-relevant PromQL queries:

```
# Component health
alloy_component_controller_running_components

# Failed authentications to OTLP endpoint
rate(alloy_http_request_duration_seconds_count{code=~"4.."}[$__rate_interval])
```

```
# TLS handshake failures
rate(alloy_tls_handshake_errors_total[$__rate_interval])

# Secret reload events
rate(alloy_config_loaded_total[$__rate_interval])

# WAL corruption
alloy_wal_corruptions_total
```

10.2 — Security Event Alerting

```
groups:
  - name: alloy-security
    rules:
      - alert: AlloyRunningAsRoot
        expr: alloy_process_uid == 0
        for: 1m
        labels:
          severity: critical
          team: security
        annotations:
          summary: "Alloy is running as root"

      - alert: AlloyTLSHandshakeFailures
        expr: rate(alloy_tls_handshake_errors_total[5m]) > 0.1
        for: 5m
        labels:
          severity: warning
          team: security
        annotations:
          summary: "Alloy experiencing TLS handshake failures"
```

```
      - alert: AlloyUnexpectedRestarts
        expr:
rate(kube_pod_container_status_restarts_total{container="alloy"}[1
5m]) > 0
        for: 5m
        labels:
          severity: warning
          team: platform
        annotations:
          summary: "Alloy pod restarting unexpectedly"

      - alert: AlloyConfigReloadFailed
        expr: alloy_config_last_load_successful == 0
        for: 5m
        labels:
          severity: critical
          team: platform
        annotations:
          summary: "Alloy configuration reload failed"
```

---

11. Security Hardening Checklist

Universal

- [ ] Dedicated non-root service account created
- [ ] Minimum file permissions applied to all paths
- [ ] Secrets stored in secrets manager (not plaintext)
- [ ] All credentials referenced via environment variables
- [ ] TLS enabled on all listeners (min TLS 1.2)

- [ ] TLS enabled on all outbound connections
- [ ] insecure_skip_verify = false everywhere
- [ ] Alloy UI restricted to localhost
- [ ] Alloy version pinned to specific release
- [ ] Binary integrity verified (checksum)
- [ ] Sensitive data scrubbing in log pipeline
- [ ] Audit logging enabled
- [ ] Monitoring and alerting for Alloy health
- [ ] Secret rotation schedule documented
- [ ] Incident response plan includes Alloy compromise

macOS Specific

- [ ] Service account created with nologin shell
- [ ] Launchd plist hardened with sandbox profile
- [ ] Alloy binary code-signed and Gatekeeper verified
- [ ] macOS Firewall enabled and Alloy restricted
- [ ] Secrets stored in macOS Keychain
- [ ] File permissions verified (700 secrets dir)

Linux Specific

- [ ] Systemd service hardened (NoNewPrivileges etc.)
- [ ] AppArmor or SELinux profile active and enforcing
- [ ] systemd-analyze security score acceptable
- [ ] Capabilities removed from binary and process
- [ ] AIDE file integrity monitoring configured
- [ ] Seccomp profile applied
- [ ] ProtectSystem=strict in service unit
- [ ] PrivateTmp=true in service unit

Windows Specific

- [ ] Service account created with no interactive login

- [ ] File ACLs applied (no world access)
- [ ] Service runs under dedicated account
- [ ] Windows Firewall rules configured
- [ ] Secrets stored in Windows Credential Manager
- [ ] Audit policy enabled for Alloy directories
- [ ] Windows Defender exclusion configured correctly
- [ ] Event log forwarding enabled

Kubernetes Specific

- [ ] Pod Security Standards = restricted
- [ ] runAsNonRoot = true
- [ ] readOnlyRootFilesystem = true
- [ ] allowPrivilegeEscalation = false
- [ ] capabilities.drop = ALL
- [ ] seccompProfile = RuntimeDefault
- [ ] AppArmor profile = runtime/default
- [ ] NetworkPolicy — default deny all
- [ ] NetworkPolicy — only required egress allowed
- [ ] RBAC — minimum required permissions
- [ ] automountServiceAccountToken = false
- [ ] Secrets via External Secrets Operator
- [ ] Image digest pinned (not mutable tag)
- [ ] Resource limits and requests set
- [ ] Falco rules deployed
- [ ] Kyverno policies enforcing standards
- [ ] PodDisruptionBudget configured

---

12. Frequently Asked Questions

Q: Should I disable the Alloy UI entirely in production?

In production, you should bind the Alloy UI to **localhost only** (--server.http.listen-addr=127.0.0.1:12345). This prevents external access while still allowing authorised engineers to access it via SSH tunnel or kubectl port-forward. Disabling it entirely removes valuable debugging capability.

Q: Can Alloy run as a completely unprivileged process?

Yes, and it should. On Linux, the only exception may be if you need Alloy to read logs from paths that require elevated permissions. In that case, add the alloy user to the adm group (usermod -aG adm alloy) rather than running Alloy as root.

Q: How do I handle certificate rotation without downtime?

Use **cert-manager** in Kubernetes for automatic rotation. On bare metal, use **Vault PKI** with Vault Agent to automatically rotate certificates and trigger a config reload via systemctl reload alloy (Alloy supports SIGHUP for config reloads without full restart).

Q: Is it safe to use the same Alloy instance for multiple teams?

From a security perspective, a shared Alloy instance increases blast radius. If one team's misconfiguration causes a credential leak, it affects all teams sharing that instance. The recommended approach is **per-team Alloy instances** with separate credentials and network isolation.

Q: How do I verify my Kubernetes Alloy deployment is truly hardened?

Run kubectl get pod <alloy-pod> -o yaml and verify all security context fields. Additionally run kube-score score deployment.yaml and trivy k8s --report summary namespace alloy to scan for security issues. The systemd-analyze security equivalent for Kubernetes is checking against the CIS Kubernetes Benchmark.

Reference Resources

Resource	Location
Grafana Alloy Security Documentation	grafana.com/docs/alloy/latest/security
Grafana Alloy Configuration Reference	grafana.com/docs/alloy/latest/reference
CIS Kubernetes Benchmark	cisecurity.org/benchmark/kubernetes
NSA Kubernetes Hardening Guide	nsa.gov/Press-Room/News-Highlights/Article/kubernetes
Pod Security Standards	kubernetes.io/docs/concepts/security/pod-security-standards
AppArmor Documentation	apparmor.net
SELinux User Guide	selinuxproject.org
Falco Documentation	falco.org/docs
HashiCorp Vault Agent	vaultproject.io/docs/agent
External Secrets Operator	external-secrets.io